

Cyber Security

Network Attacks

By
Dr. Mudassar Raza
Professor
Department of Computer Science
Namal University Mianwali



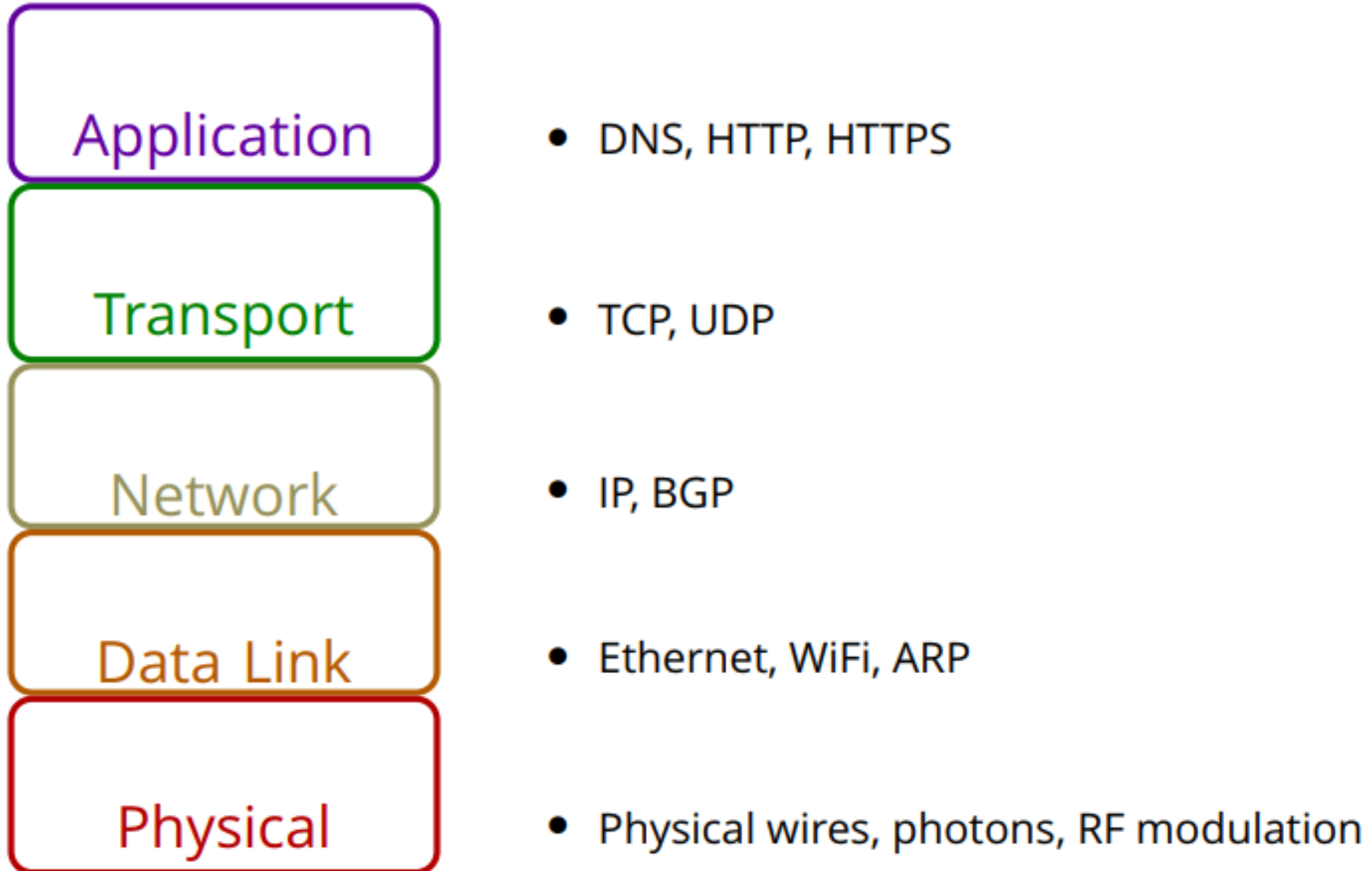
https://techgirls.ece.vt.edu/slides/introduction_to_cybersecurity.html#39

Threat modeling for network attacks

Attacker capabilities:

- **Physical access:** Attacker has physical access to the network infrastructure.
- **In path/Man in the middle:** Attacker can see, add, and block packets.
- **On path/Man on the side:** Attacker can see and add packets, but cannot block packets.
- **Passive:** Attacker can see victim's network traffic, but cannot add or modify packets.
- **Off path:** Attacker cannot see network traffic of the victim.

Different attacks at different layers

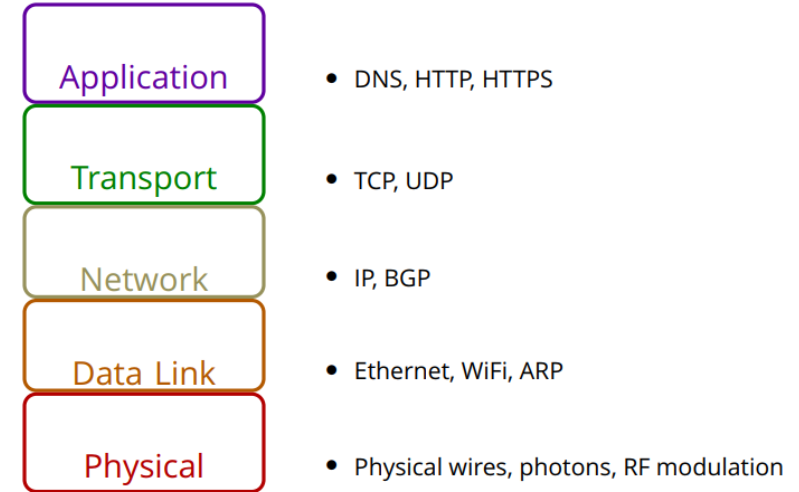


Physical/link layer threats

Eavesdropping: Violates confidentiality.

Who can see the packets you send?

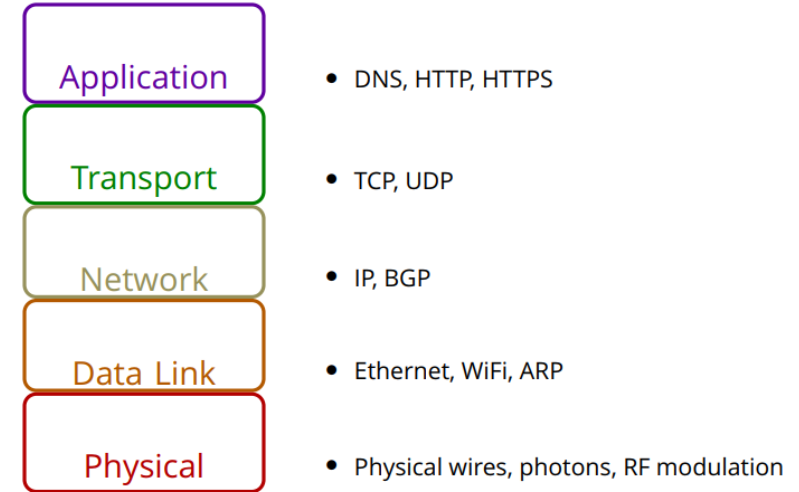
- Network (routers, switches, access points) see all traffic passing by.



Physical/link layer threats

Injection: Violates integrity.

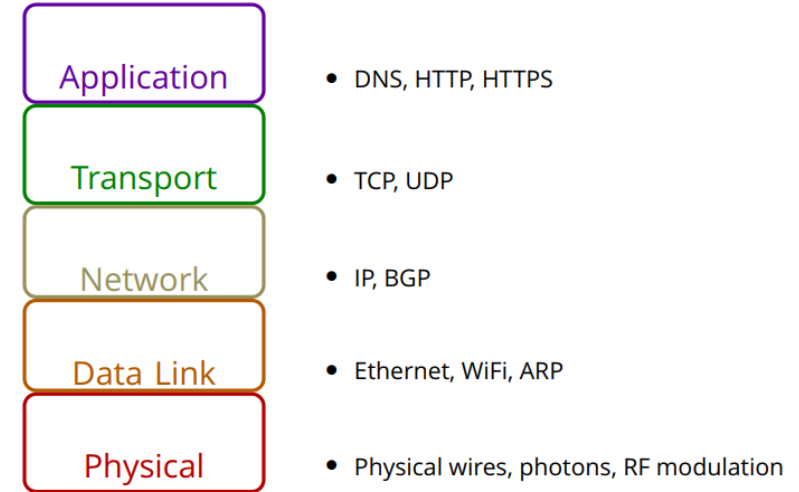
- Ethernet packets are unauthenticated: attacker who can inject traffic can create a frame with any addresses they like.



Packet injection: ARP spoofing

ARP used to map IP addresses to MAC addresses on local network

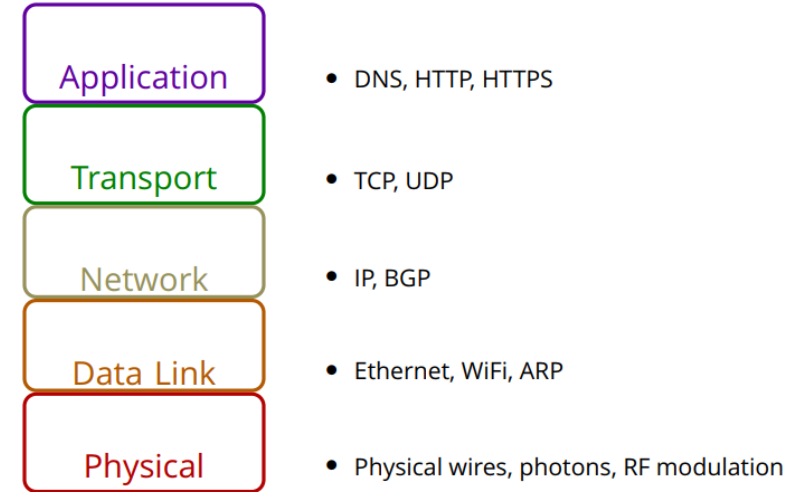
- ARP requests broadcast to local subnetwork
- Anyone can send an ARP response
- Attacker on local network can impersonate any other host.



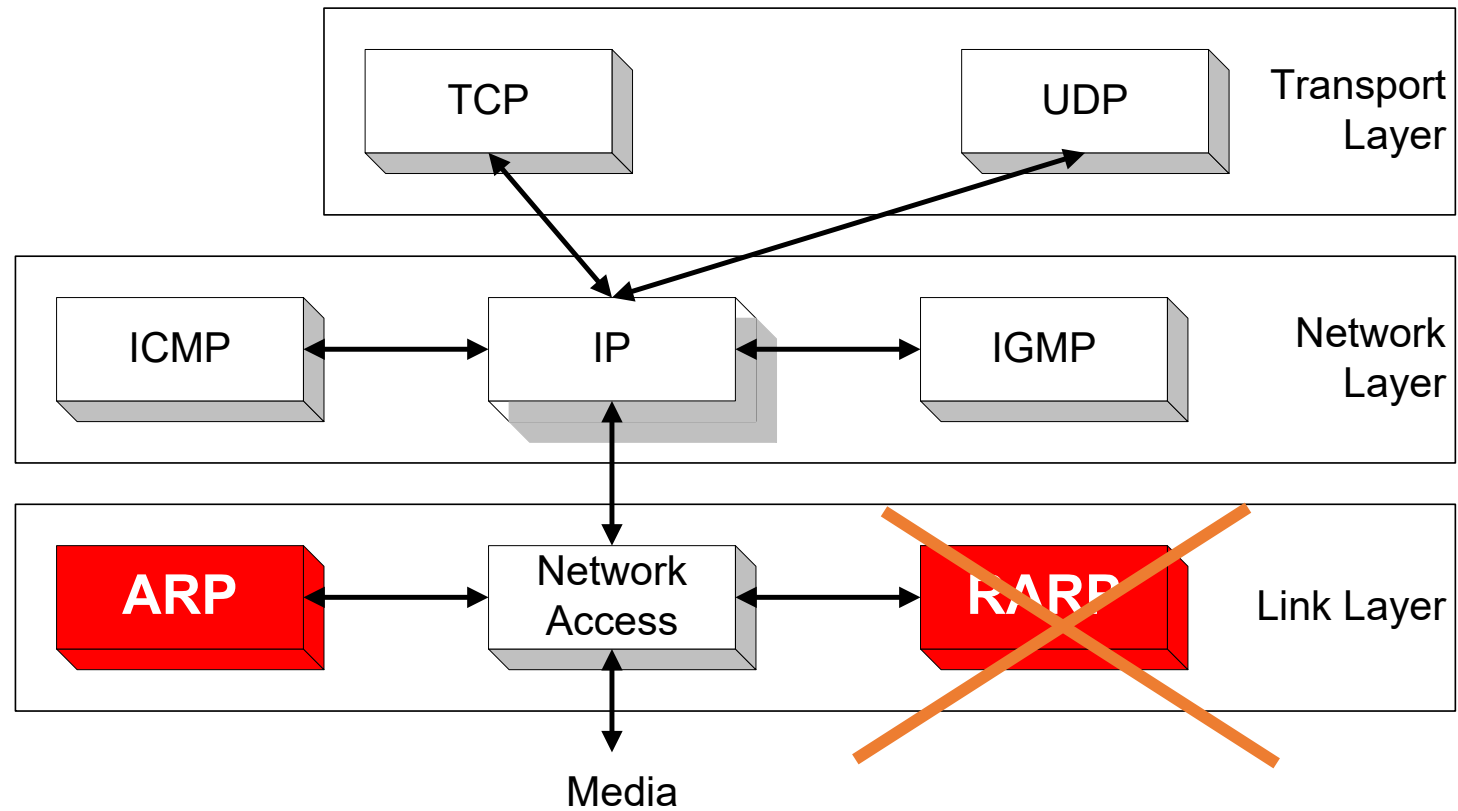
Packet injection: ARP spoofing

ARP used to map IP addresses to MAC addresses on local network

- ARP requests broadcast to local subnetwork
- Anyone can send an ARP response
- Attacker on local network can impersonate any other host.

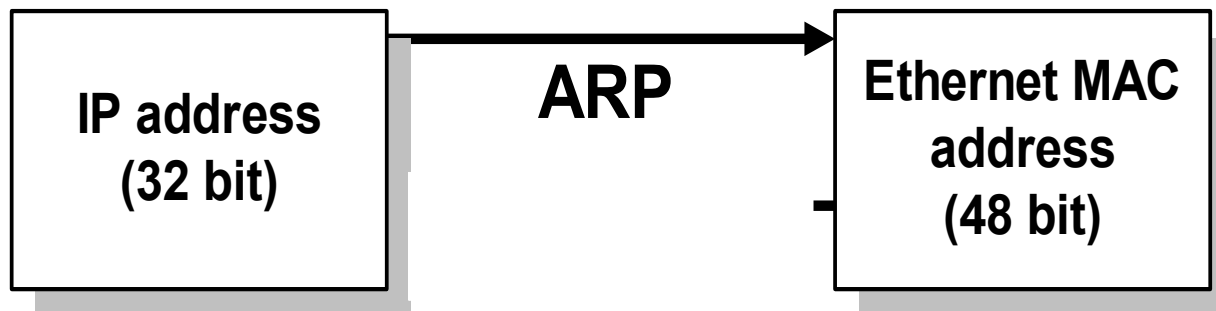


Overview



ARP and RARP

- Note:
 - The Internet is based on IP addresses
 - Data link protocols (Ethernet, FDDI, ATM) may have different (MAC) addresses
- The ARP and RARP protocols perform the **translation between IP addresses and MAC layer addresses**
- We will discuss ARP for broadcast LANs, particularly Ethernet LANs



Address Translation with ARP

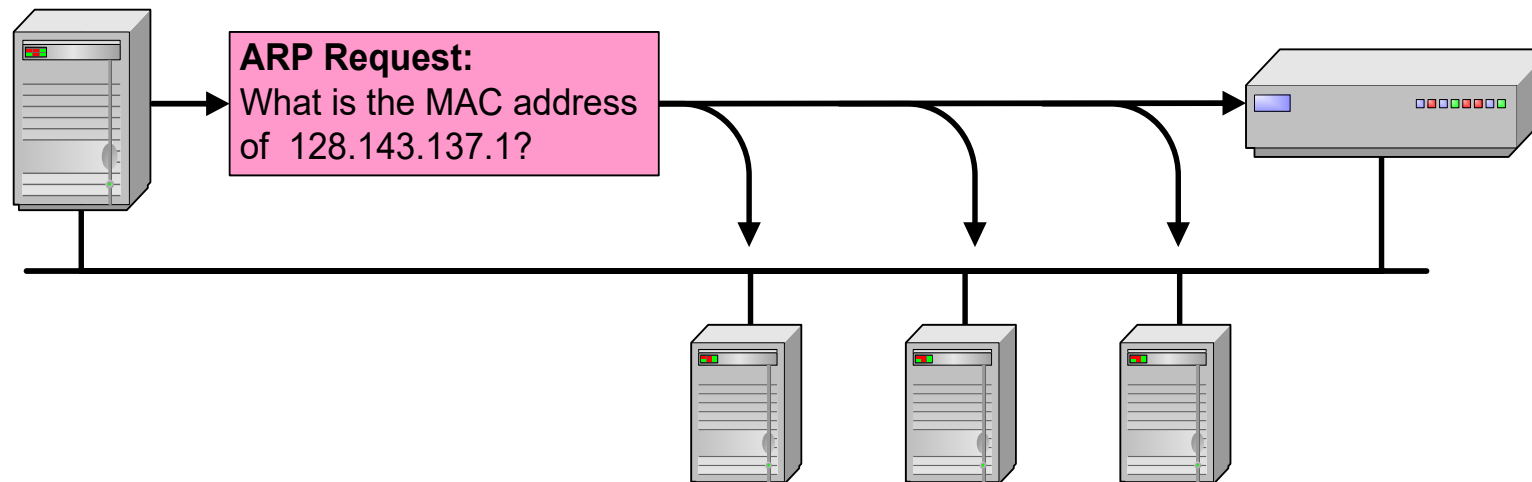
ARP Request:

Argon broadcasts an ARP request to all stations on the network:

“What is the hardware address of Router137?”

Argon
128.143.137.144
00:a0:24:71:e4:44

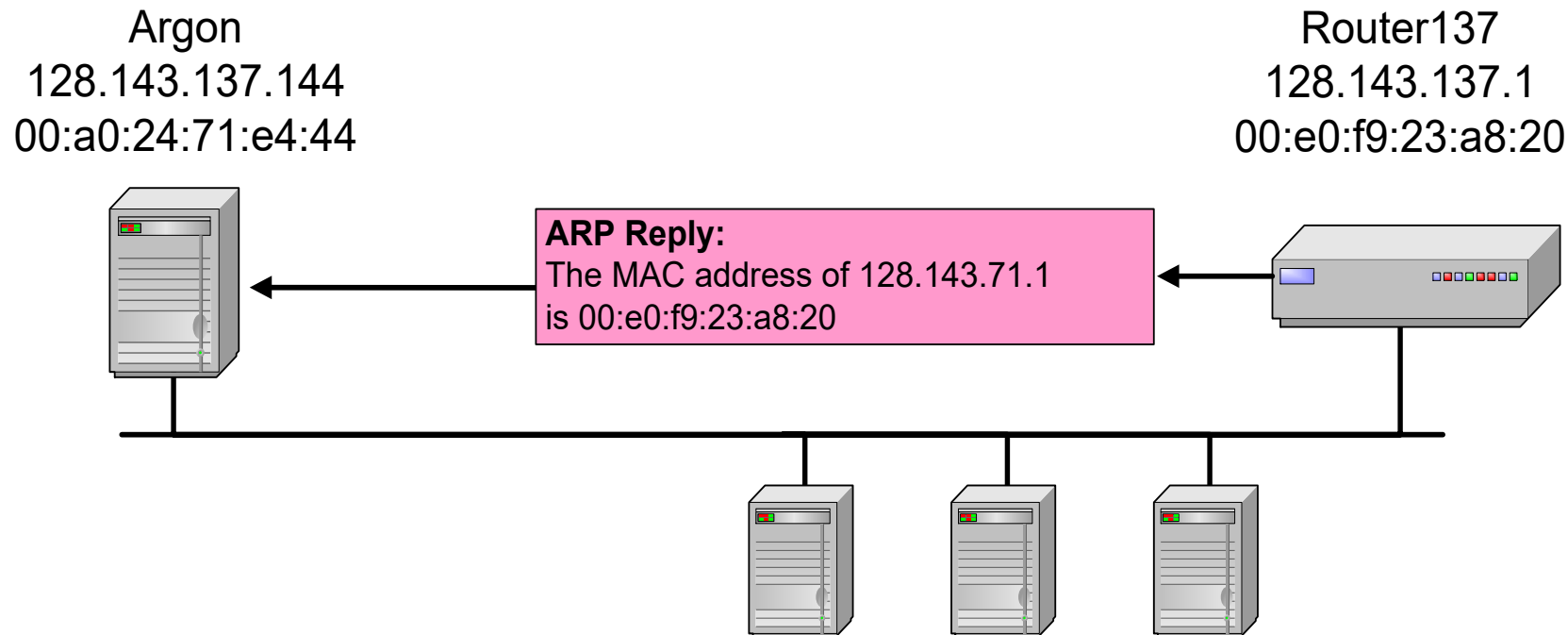
Router137
128.143.137.1
00:e0:f9:23:a8:20



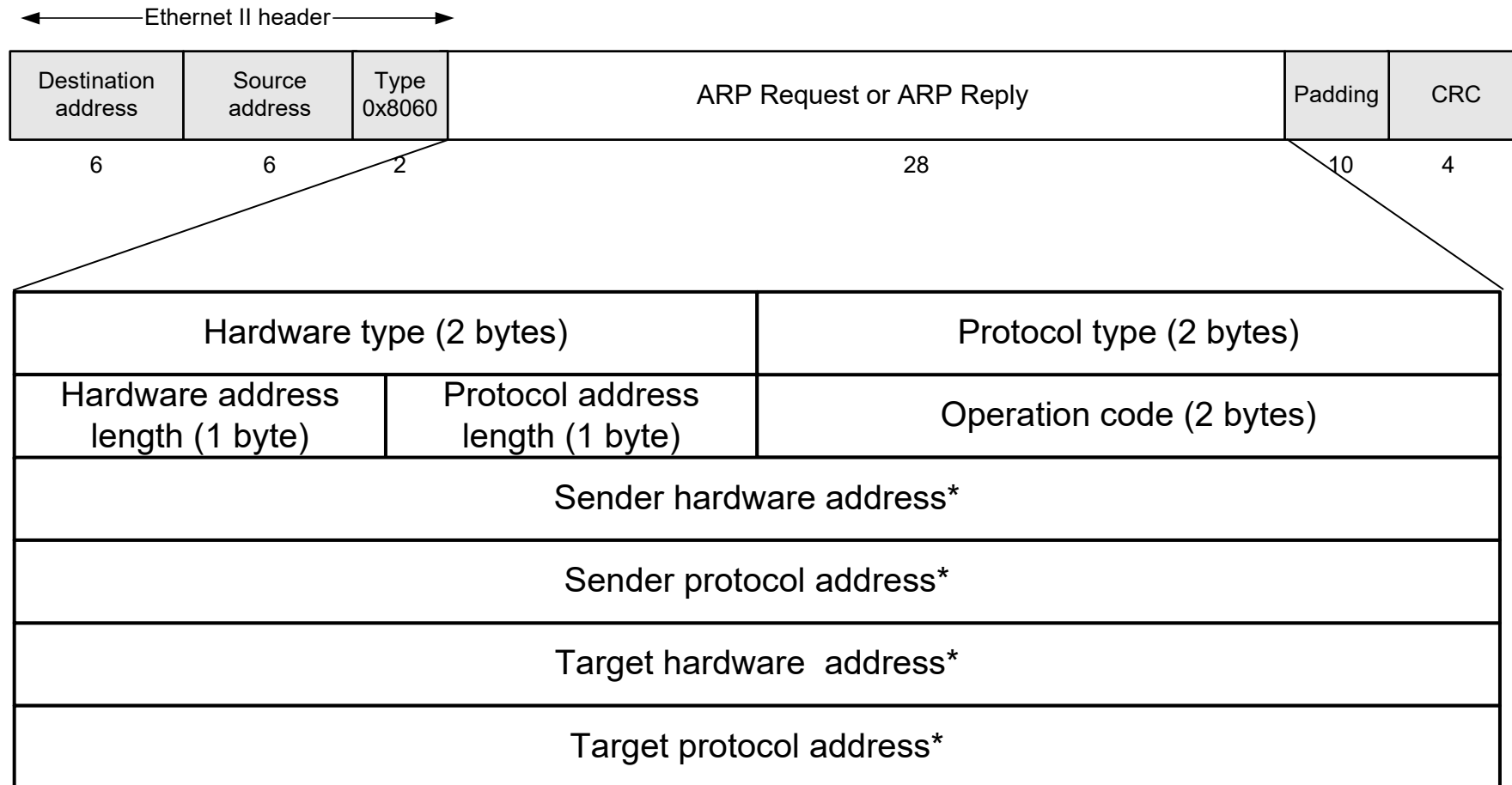
Address Translation with ARP

ARP Reply:

Router 137 responds with an ARP Reply which contains the hardware address



ARP Packet Format



* Note: The length of the address fields is determined by the corresponding address length fields

Example

- *ARP Request from Argon:*

Source hardware address: 00:a0:24:71:e4:44
Source protocol address: 128.143.137.144
Target hardware address: 00:00:00:00:00:00
Target protocol address: 128.143.137.1

- *ARP Reply from Router137:*

Sender hardware address: 00:e0:f9:23:a8:20
Sender protocol address: 128.143.137.1
Target hardware address: 00:a0:24:71:e4:44
Target protocol address: 128.143.137.144

ARP Cache

- Since sending an ARP request/reply for each IP datagram is inefficient, hosts maintain a cache (ARP Cache) of current entries. The entries expire after 20 minutes.
- Contents of the ARP Cache:
 - (128.143.71.37) at 00:10:4B:C5:D1:15 [ether] on eth0
 - (128.143.71.36) at 00:B0:D0:E1:17:D5 [ether] on eth0
 - (128.143.71.35) at 00:B0:D0:DE:70:E6 [ether] on eth0
 - (128.143.136.90) at 00:05:3C:06:27:35 [ether] on eth1
 - (128.143.71.34) at 00:B0:D0:E1:17:DB [ether] on eth0
 - (128.143.71.33) at 00:B0:D0:E1:17:DF [ether] on eth0

Things to know about ARP

- What happens if an ARP Request is made for a non-existing host?

Several ARP requests are made with increasing time intervals between requests. Eventually, ARP gives up.

- On some systems (including Linux) a host periodically sends ARP Requests for all addresses listed in the ARP cache. This refreshes the ARP cache content, but also introduces traffic.
- **Gratuitous ARP Requests:** A host sends an ARP request for its own IP address:
 - Useful for detecting if an IP address has already been assigned.

Vulnerabilities of ARP

1. Since ARP does not authenticate requests or replies, ARP Requests and Replies can be forged
2. ARP is stateless: ARP Replies can be sent without a corresponding ARP Request
3. According to the ARP protocol specification, a node receiving an ARP packet (Request or Reply) must update its local ARP cache with the information in the source fields, if the receiving node already has an entry for the IP address of the source in its ARP cache. (This applies to ARP Request packets and to ARP Reply packets)

Typical exploitation of these vulnerabilities:

- A forged ARP Request or Reply can be used to update the ARP cache of a remote system with a forged entry (**ARP Poisoning**)
- This can be used to redirect IP traffic to other hosts

Demo – ARP Cache

- Host.141 has not communicated with .143
 - .141's ARP cache probably doesn't contain an entry for .143
- Host .141 makes a web request to .143
 - ARP for .143's physical address
 - Added to .141's cache
 - Web request sent and reply received

ARP Cache Poisoning

- Broadcast ARP replies associating your physical address with a given IP address
 - Other hosts receive this message and put the mapping into their ARP cache
 - When a machine wants to communicate with the given IP address it sends the frame to your physical address
 - You read the frame and then forward it on to the real destination host

Cain and Abel

- A man-in-the-middle LAN attack tool
 - Sniffer
 - Protocol analyzer
- URL: <http://www.oxid.it/cain.html>
- Can be used to poison hosts ARP caches

Demo – ARP Cache Poisoning

- Hosts .142 and .143 may or may not have communicated
 - ARP caches may or may not contain entries for each other
- Start Cain (on .141) and poison both .142 and .143's ARP caches:
 - .142's HW address associated with .141's IP
 - .143's HW address associated with .141's IP

ARP Cache Poisoning - Result

- .142 and .143 will communicate with each other
 - May not realize that their communications are flowing through a third-party
- All communications will flow through .141
 - .141 can read/store traffic
 - .141 forwards between the two hosts

Example – An FTP Connection

- Switched Environment
 - Source host: .143
 - Destination host: .142
 - Attacker: .141
- Using:
 - Cain and Abel

ARP Poisoning

- Can:
 - Read traffic
 - Modify traffic

Example – DNS Spoofing

- Switched Environment
 - Source host: .143
 - Destination host: Google
 - Attacker: .141
- Using:
 - Cain and Abel

Example – SSH Downgrade

- Switched Environment
 - Source host: my laptop
 - Destination host: .147
 - Attacker: .141
- Using:
 - Cain and Abel

ARP Poisoning

- What attackers look for:
 - Sensitive, unencrypted communications
 - Web requests/replies, e-mail, FTP
 - Weakly-encrypted communications
 - Old versions of SSH, RDC

ARP Poisoning - Countermeasures

- Static ARP tables/smart switch
- ARPwatch
- IDS

Thank You